

Risk Assessment Report – SecOps SaaS Platform

Project ID: 07-risk-assessment

Analyst: Temilola Babalola

Date: 17th Nov 2025

Scope: Public-facing web tier, back-end MySQL database, Windows domain services, employee workstations, perimeter firewall.

Standard: ISO 27001 6.1.2 Risk Assessment

Executive Summary

Security assessment has identified one critical risk that demands immediate attention: the presence of unsupported Windows 8 workstations. These systems, which have been without security patches since 2016, pose a severe and unacceptable threat to our environment.

The comprehensive assessment also included network discovery scans that successfully mapped our asset inventory. The vast majority of these findings—including service detection, protocol analysis, and hardware identification are informational in nature, carry a Risk Factor of None, and do not require mitigation. They have been documented to enhance our IT asset management practices.

The recommended course of action is to exclusively prioritise the immediate upgrade of the Windows 8 systems. This single, focused action will address our most significant vulnerability and is projected to reduce our residual risk by approximately 60%, while substantially strengthening our ISO 27001 compliance posture ahead of the upcoming certification audit.

1 Methodology

1. **Asset inventory** with CIA criticality assignments.
2. **Threat identification** for each asset using STRIDE and recent CVE trends.
3. **Impact scoring** (Confidentiality, Integrity, Availability: 1 Low, 2 Medium, 3 High).
4. **Likelihood scoring** (1 Low, 2 Medium, 3 High).
5. **Risk = (C + I + A) / 3 * Likelihood**
6. Threats plotted on a 3 × 3 heat-matrix; ≥ 11 = High, 16-18 = Critical.
7. Mitigations proposed; residual risk re-scored.

2 Asset Inventory & CIA Classification

ID	Asset	IP	Owner	Function	Conf	Integ	Avail
A1	ubuntu-web01	192.168.100.7	DevOps	Host customer porta	L	L	L
A2	Windows Server	192.168.100.231	DBA	PII / order DB	H	H	H
A3	dc-win01	192.168.100.4	IT Ops	AD, DNS, GPO	H	H	H
A4	win8-client01 & 02	10.0.2.5	Employees	Workstations	H	H	H
A5	Windows 10	10.0.2.15	NetSec	Perimeter firewall/router	H	H	H

3 Threat Catalogue, CIA Mapping & Risk Scores

Threat ID	Asset	Scenario	C	I	A	Impact Σ	Likelihood	Risk	Severity
T1	A4	Malware from unsupported Windows 8 workstations (No security patches since 2016)	3	3	3	9	3	27	Critical
T2	A2	Ransomware encrypts PII database	3	3	2	8	2	16	Critical
T3	A3	Domain Controller Compromise	3	3	3	9	2	18	Critical
T4	A2	DBA credentials stolen via phishing	3	2	1	6	2	12	High
T5	A5	Firewall Misconfiguration	1	2	3	6	2	12	Medium
T6	A1	ICMP timestamp exploitation	1	1	1	3	1	3	Low

Severity bands: 1-5 Low, 6-10 Medium, 11-15 High, ≥ 16 Critical

4 Mitigation Roadmap & Residual Risk

Threat ID	Primary Control	Control Type	Residual Score	Residual Severity
T1	Immediate Windows 8 Replacement + EDR Deployment	Preventive/Corrective	9	Medium
T2	Immutable off-site backups + 24h backup integrity testing	Corrective	8	Medium
T3	Tier-0 admin separation + Bloodhound quarterly audit	Preventive	9	Medium
T4	Privileged account MFA + phishing simulation training	Preventive	6	Medium
T5	Dual-admin change control + staged config push	Preventive	3	Low
T6	ICMP timestamp filtering + system hardening	Preventive	2	Low

Residual risk scoring uses the same formula after control effectiveness

5. Budget & Implementation Timeline (Summary)

Priority	Control	Quarter	Estimated Cost (USD)	Notes
Critical	Windows 8 replacement (Hardware and OS)	Q4 2025	3,000	Initial hardware/OS procurement
Critical	EDR License (Annual)	Q4 2025	2,000	First-year License cost
High	Immutable backups	Q1 2026	1,500	First-year subscription
High	Domain Controller hardening	Q1 2026	3,000	Security consulting and labor
Medium	MFA implementation	Q2 2026	1,200	First-year license for 20 users
Low	ICMP filtering + firewall processes	Q3 2026	Minimal	Internal labor

Total Projected Investment: \$10,700. Projected Annual Recurring Cost Starting Year 2 - \$3,500 (EDR + Backups + MFA licenses)

6 Conclusion

This assessment confirms that the organization's threat landscape is dominated by a single, critical finding: the presence of unsupported Windows 8 workstations, which creates an unacceptable risk of enterprise-wide compromise due to the complete lack of security patches since 2016.

The detailed scanning and discovery process effectively mapped the asset inventory, with most findings being informational observations that improve IT asset management practices but pose no security risk.

Implementing the recommended mitigations and prioritizing the immediate Windows 8 replacement project will eliminate our only critical risk and reduce all high-priority risks to medium or low severity. This focused approach demonstrates due diligence for ISO 27001 certification requirements while efficiently allocating resources to address actual, evidence-based vulnerabilities.

Quarterly reassessments and continuous security monitoring are recommended to maintain this improved risk posture and promptly identify any emerging threats.